

HiveForce Labs

THREAT ADVISORY

 VULNERABILITY REPORT

The Exploitation of Critical Zero-Day Vulnerability Found in MOVEit Transfer

Date of Publication

June 05, 2023

Admiralty Code

A1

TA Number

TA2023251

Summary

First Seen: May 31, 2023

Affected Platforms: Progress MOVEit Transfer

Malware: Clop Ransomware

Threat Actor: Lace Tempest (aka FIN11, DEV-0950), TA505 (Graceful Spider, Gold Evergreen, Gold Tahoe, TEMP.Warlock, ATK 103, SectorJ04, Hive0065, Chimborazo, Spandex)

Impact: The MOVEit Transfer vulnerability is that it allows for unauthorized access to the database, potential manipulation or deletion of its contents, and exploitation of affected systems.

CVE

CVE	NAME	AFFECTED PRODUCT	ZERO -DAY	CISA KEV	PATCH
CVE-2023-34362	Progress MOVEit Transfer SQL Injection Vulnerability	Progress MOVEit Transfer			

Vulnerability Details

#1

CVE-2023-34362 is a zero-day vulnerability that affects MOVEit Transfer, a file transfer software. This vulnerability is categorized as a SQL injection flaw, which means that it allows an attacker to inject malicious SQL code into the application's database queries. Exploiting this vulnerability can result in unauthorized access to the MOVEit Transfer database, as well as potential manipulation or deletion of its contents. The vulnerability was discovered in May 2023 and has been actively exploited in the wild. Attackers can exploit this vulnerability through both HTTP and HTTPS protocols. All versions of MOVEit Transfer are affected.

#2

This vulnerability has been exploited by Lace Tempest (aka FIN11, DEV-0950), a threat actor group known for ransomware activities and operating the Clop extortion site. This exploit allows attackers to authenticate as any user and enables data exfiltration. Lace Tempest has a track record of using similar vulnerabilities to steal data and extort victims. Additionally, the threat actor group TA505 is also taking advantage of this MOVEit Transfer SQL Injection Vulnerability.

Vulnerabilities

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2023-34362	MOVEit Transfer 2023.0.0 (15.0) MOVEit Transfer 2022.1.x (14.1) MOVEit Transfer 2022.0.x (14.0) MOVEit Transfer 2021.1.x (13.1) MOVEit Transfer 2021.0.x (13.0) MOVEit Transfer 2020.1.x (12.1) MOVEit Transfer 2020.0.x (12.0) or older MOVEit Cloud	cpe:2.3:a:progress:moveit_transfer:*:*:*:*:*	CWE-89

Recommendations



Disable all HTTP and HTTPS traffic: Modify firewall rules to deny traffic on ports 80 and 443 to prevent further exploitation until the patch can be applied. This temporary measure will impact certain functionalities like user logins, MOVEit Automation tasks, and REST/Java/.NET APIs. However, SFTP and FTP/s protocols will continue to function normally.



Review, delete, and reset to eliminate unauthorized files and user accounts. This includes searching for specific file instances and directories, reviewing logs for suspicious activities, and considering the reset of affected credentials.



Apply the relevant [patch](#), Progress has provided patches for supported MOVEit Transfer versions. Apply the appropriate [patch](#) as per their official documentation.



Verify compromised files and unauthorized accounts: Ensure that the deletion and reset procedures were successful by following the necessary steps and confirming the removal of compromised files and unauthorized accounts.



Implement continuous monitoring: Monitor the network, endpoints, and logs for Indicators of Compromise ([IoCs](#)) provided by Progress. This helps in detecting and responding to any potential security incidents.



Potential MITRE ATT&CK TTPs

<u>TA0005</u> Defense Evasion	<u>TA0007</u> Discovery	<u>TA0002</u> Execution	<u>TA0040</u> Impact
<u>TA0003</u> Persistence	<u>T1203</u> Exploitation for Client Execution	<u>T1068</u> Exploitation for Privilege Escalation	<u>TA0004</u> Privilege Escalation
<u>T1588</u> Obtain Capabilities	<u>T1588.006</u> Vulnerabilities	<u>T1588.005</u> Exploits	<u>T1071</u> Application Layer Protocol



Indicators of Compromise (IOCs)

TYPE	VALUE
Folder Path	C:\Windows\TEMP\[random]\[random].cmdline C:\Windows\Microsoft[.]NET\Framework64\v4[.]0[.]30319\Temporary ASP[.]NET Files\root\[random]\[random]\App_Web_[random][.]dll
File Name	human2[.]aspx human2[.]aspx[.]lnk
HTTP Request	POST /moveitisapi/moveitisapi[.]dll POST /guestaccess[.]aspx POST /api/v1/folders/[random]/files GET /human2[.]aspx
User Account	Health Check Service
Domain	dojustit[.]mo00[.]com
User Agent	Mozilla/5[.]0+(Windows+NT+10[.]0;+Win64;+x64)+AppleWebKit/537[.]36+(KHTML,+like+Gecko)+Chrome/105[.]0[.]5195[.]102+Safari/537[.]36
CIDR	188[.]241[.]58[.]0/24 5[.]252[.]189[.]0/24 5[.]252[.]190[.]0/24 5[.]252[.]191[.]0/24



TYPE	VALUE
IPV4	5[.]252[.]23[.]116 5[.]252[.]25[.]88 84[.]234[.]96[.]104 89[.]39[.]105[.]108 138[.]197[.]152[.]201 148[.]113[.]152[.]144 198[.]12[.]76[.]214 209[.]97[.]137[.]33 209[.]222[.]103[.]170 104[.]194[.]222[.]107 146[.]0[.]77[.]141 146[.]0[.]77[.]155 146[.]0[.]77[.]183 162[.]244[.]34[.]26 162[.]244[.]35[.]6 179[.]60[.]150[.]143 185[.]104[.]194[.]156 185[.]104[.]194[.]24 185[.]104[.]194[.]40 185[.]117[.]88[.]17 185[.]162[.]128[.]75 185[.]174[.]100[.]215 185[.]174[.]100[.]250 185[.]181[.]229[.]240 185[.]181[.]229[.]73 185[.]183[.]32[.]122 185[.]185[.]50[.]172 188[.]241[.]58[.]244 193[.]169[.]245[.]79 194[.]33[.]40[.]103 194[.]33[.]40[.]104 194[.]33[.]40[.]164 198[.]27[.]75[.]110 206[.]221[.]182[.]106 209[.]127[.]116[.]122 209[.]127[.]4[.]22 45[.]227[.]253[.]133 45[.]227[.]253[.]147 45[.]227[.]253[.]50 45[.]227[.]253[.]6 45[.]227[.]253[.]82 45[.]56[.]165[.]248 5[.]149[.]248[.]68 5[.]149[.]250[.]74 5[.]149[.]250[.]92 5[.]188[.]86[.]114 5[.]188[.]86[.]250 5[.]188[.]87[.]194

TYPE	VALUE
IPV4	5[.]188[.]87[.]226 5[.]188[.]87[.]27 5[.]34[.]180[.]205 62[.]112[.]11[.]57 62[.]182[.]82[.]19 62[.]182[.]85[.]234 66[.]85[.]26[.]215 66[.]85[.]26[.]234 66[.]85[.]26[.]248 79[.]141[.]160[.]78 79[.]141[.]160[.]83 84[.]234[.]96[.]31 89[.]39[.]104[.]118 91[.]202[.]4[.]76 91[.]222[.]174[.]95 91[.]229[.]76[.]187 93[.]190[.]142[.]131
SHA256	0b3220b11698b1436d1d866ac07cc90018e59884e91a8cb71ef8924309f1e0e9 110e301d3b5019177728010202c8096824829c0b11bb0dc0bff55547ead18286 1826268249e1ea58275328102a5a8d158d36b4fd312009e4a2526f0bfbc30de2 2ccf7e42afd3f6bf845865c74b2e01e2046e541bb633d037b05bd1cdb296fa59 58ccfb603cdc4d305fddd52b84ad3f58ff554f1af4d7ef164007cb8438976166 98a30c7251cf622bd4abce92ab527c3f233b817a57519c2dd2bf8e3d3ccb7db8 a8f6c1ccba662a908ef7b0cb3cc59c2d1c9e2cbbe1866937da81c4c616e68986 b5ef11d04604c9145e4fe1bedaeb52f2c2345703d52115a5bf11ea56d7fb6b03 cec425b3383890b63f5022054c396f6d510fae436041add935cd6ce42033f621 ed0c3e75b7ac2587a5892ca951707b4e0dd9c8b18aaf8590c24720d73aa6b90c 0b3220b11698b1436d1d866ac07cc90018e59884e91a8cb71ef8924309f1e0e9 110e301d3b5019177728010202c8096824829c0b11bb0dc0bff55547ead18286 1826268249e1ea58275328102a5a8d158d36b4fd312009e4a2526f0bfbc30de2 2ccf7e42afd3f6bf845865c74b2e01e2046e541bb633d037b05bd1cdb296fa59 58ccfb603cdc4d305fddd52b84ad3f58ff554f1af4d7ef164007cb8438976166 98a30c7251cf622bd4abce92ab527c3f233b817a57519c2dd2bf8e3d3ccb7db8

TYPE	VALUE
SHA256	a8f6c1ccba662a908ef7b0cb3cc59c2d1c9e2cbbe1866937da81c4c616e68986 b5ef11d04604c9145e4fe1bedae52f2c2345703d52115a5bf11ea56d7fb6b03 cec425b3383890b63f5022054c396f6d510fae436041add935cd6ce42033f621 ed0c3e75b7ac2587a5892ca951707b4e0dd9c8b18aaf8590c24720d73aa6b90c

🔗 Patch Details

<https://community.progress.com/s/article/MOVEit-Transfer-Critical-Vulnerability-31May2023>

🔗 References

<https://www.bleepingcomputer.com/news/security/new-moveit-transfer-zero-day-mass-exploited-in-data-theft-attacks/>

<https://twitter.com/MsftSecIntel/status/1665537734746816512>

<https://twitter.com/MsftSecIntel/status/1665537730946670595>

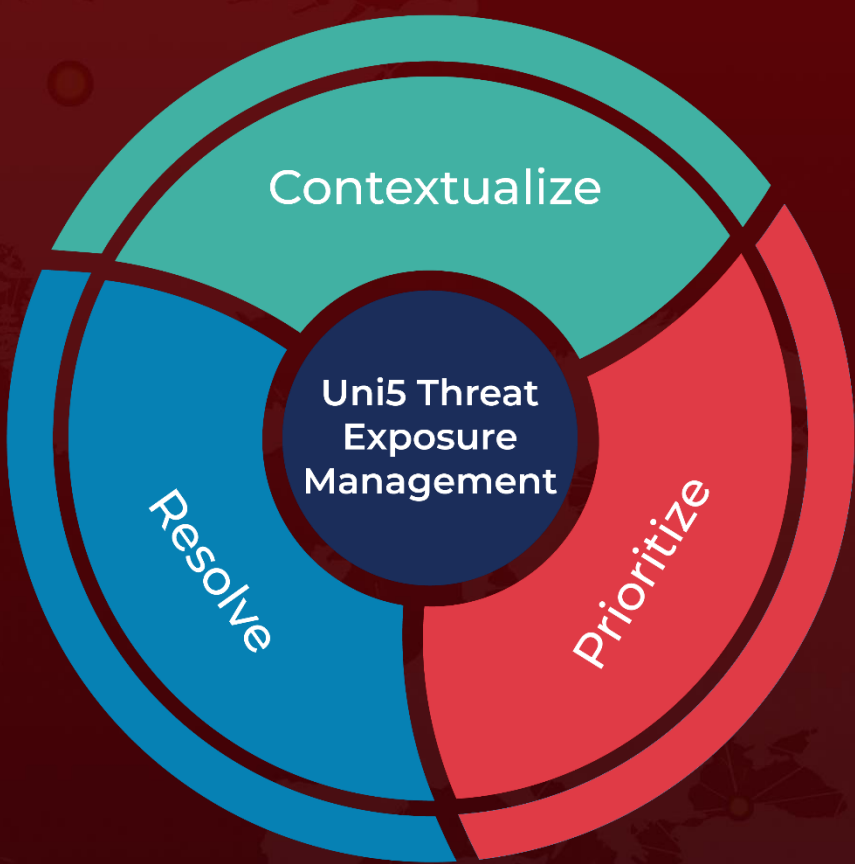
<https://www.rapid7.com/blog/post/2023/06/01/rapid7-observed-exploitation-of-critical-moveit-transfer-vulnerability/>

<https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-158a>

What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with HivePro Uni5: Threat Exposure Management Platform.



REPORT GENERATED ON
June 05, 2023 • 3:30 AM

© 2023 All Rights are Reserved by HivePro



More at www.hivepro.com